

Executive Briefing: High-Priority Risk Mitigation (CISA KEV 2026-03)

Office of the GRC Architect

March 10, 2026

1 Issue Overview

On March 6, 2026, the Cybersecurity and Infrastructure Security Agency (CISA) added two critical vulnerabilities to the Known Exploited Vulnerabilities (KEV) catalog. These vulnerabilities affect **Hikvision** (Surveillance) and **Rockwell Automation** (Industrial Control Systems). Both carry a **CVSS score of 9.8**.

2 Critical Risk Drivers

The inclusion of these items in the KEV catalog indicates *confirmed, active exploitation* by threat actors. This is no longer a theoretical risk.

- **Operational Risk:** Potential shutdown of manufacturing lines (Rockwell).
- **Physical Risk:** Compromise of site security and unauthorized surveillance (Hikvision).
- **Compliance Risk:** Violation of BOD 22-01 mandates and potential cyber insurance invalidation.

3 Strategic Impact

Unlike standard IT vulnerabilities, these affect the **Operational Technology (OT)** and **IoT** layers. These assets are often overlooked in standard patching cycles, creating a significant "blind spot" in the enterprise security posture.

4 Recommendation

The GRC team recommends an accelerated remediation timeline of **7 business days** for all internet-facing assets and **15 days** for internal segmented assets. This exceeds standard SLAs but is required to maintain the current risk appetite.

This document is intended for Executive Leadership and the Risk Committee.